

TAVARES CLAIMS SERVICES, INC.

Information Security Policy

Document Owner: Chief Information Security Officer (CISO)

Classification: Internal | Effective Date: 2026-03-20 | Next Scheduled Review: 2027-02-01

Fictional organization. Created for portfolio demonstration purposes.

1. Purpose

This policy establishes the framework by which Tavares Claims Services, Inc. ("the Company") protects the confidentiality, integrity, and availability of its information assets, including protected health information (PHI), personally identifiable information (PII), and proprietary business data. This policy supports compliance with HIPAA/HITECH, applicable state privacy law, and contractual obligations to customers and partners, and is informed by the NIST Cybersecurity Framework (CSF) 2.0.

2. Scope

This policy applies to all Company workforce members — employees, contractors, interns, and temporary staff — as well as third parties with access to Company systems, networks, or data. It covers all information assets owned, leased, or managed by the Company, regardless of location or format (cloud, on-premises, physical, or electronic).

3. Roles and Responsibilities

Role	Responsibility
Chief Information Security Officer (CISO)	Owns this policy; sets security strategy; reports risk posture to executive leadership and the Board.
Compliance Officer	Ensures alignment with HIPAA and other regulatory obligations; maintains Business Associate Agreements; leads breach notification process.
IT / Engineering Leadership	Implements technical controls; owns system and application security within their domain.
Vendor Risk Manager	Assesses and monitors third-party security posture per Section 9.
All Workforce Members	Comply with this policy, complete required training, and report suspected incidents promptly.

4. Data Classification & Handling

All Company data must be classified into one of the following tiers, with handling requirements scaled to sensitivity:

- **Restricted** — PHI, PII, payment data, and authentication credentials. Requires encryption at rest and in transit, least-privilege access, and audit logging.
- **Confidential** — internal business data not intended for public release (financials, contracts, source code).
- **Internal** — general internal communications and documentation.
- **Public** — information approved for public release.

Restricted data must never be stored on unmanaged personal devices, transmitted over unencrypted channels, or exported in bulk without a documented business justification and Data Governance Lead approval.

5. Access Control

Access to Company systems and data is granted on a least-privilege, role-based basis and must be formally requested, approved, and periodically reviewed.

- Multi-factor authentication (MFA) is required for all remote access, administrative accounts, and access to systems containing Restricted data.
- Standing privileged/administrative access must be minimized; just-in-time elevation is preferred for production systems.
- User access must be reviewed at least quarterly by system/data owners; access for terminated employees must be revoked within 24 hours of termination.
- Shared or generic accounts are prohibited except where technically unavoidable, and must be documented with compensating controls.

6. Encryption

Restricted and Confidential data must be encrypted at rest using AES-256 or equivalent, and in transit using TLS 1.2 or higher. Deprecated protocols (SSL, TLS 1.0/1.1) are prohibited on production systems. Encryption key management must follow documented key rotation and access procedures.

7. Acceptable Use

Company systems and accounts are provided for business purposes. Workforce members must not:

- Share credentials or authentication factors with any other individual.
- Install unauthorized software or connect unauthorized devices to Company networks.
- Use Company systems to store or transmit Restricted data through unapproved third-party services (e.g., personal cloud storage, unmanaged messaging apps).
- Disable or circumvent security controls, including endpoint protection and DLP tooling.

8. Security Awareness & Training

All workforce members must complete security awareness training upon hire and no less than annually thereafter. Workforce members in high-risk roles (e.g., Finance, HR, and personnel with access to Restricted data) must complete additional role-based training and participate in periodic phishing simulation exercises.

9. Third-Party & Vendor Risk Management

Vendors and service providers with access to Company systems or Restricted data must undergo a security assessment prior to onboarding and on a recurring basis proportional to risk tier (see Vendor Risk Assessment artifact for methodology).

- Critical-tier vendors (those with access to PHI/PII) require an on-file SOC 2 Type II report (or equivalent) and a signed Business Associate Agreement (BAA) where applicable.
- Vendor risk ratings and outstanding remediation items are tracked centrally and reviewed quarterly by the Vendor Risk Manager and Compliance Officer.

10. Incident Response

Suspected or confirmed security incidents must be reported immediately to the Security Operations team via the designated incident channel. The Company maintains a documented Incident Response Plan covering detection, containment, eradication, recovery, and post-incident review, which is tested at least every six months. Incidents involving actual or suspected unauthorized access to PHI are subject to the Company's HIPAA breach notification procedure, coordinated by the Compliance Officer.

11. Business Continuity & Disaster Recovery

Systems supporting critical business functions must have documented recovery time objectives (RTO) and recovery point objectives (RPO) established through the Business Impact Analysis process, with backup and recovery procedures tested at least annually.

12. Physical Security

Access to facilities and data centers housing Company systems must be restricted to authorized personnel, logged, and reviewed periodically. Visitors must be escorted at all times in areas housing Restricted data or production infrastructure.

13. Change Management

Changes to production systems must follow the documented change management process, including peer review and Change Advisory Board (CAB) approval for standard changes. Emergency changes are permitted but require retrospective CAB review within 48 hours of implementation.

14. Compliance & Enforcement

Compliance with this policy is mandatory. Violations may result in disciplinary action up to and including termination of employment or contract, and may be reported to regulatory authorities where required by law.

15. Exceptions and Risk Acceptance

A policy exception must be requested in writing and approved by the CISO, with documented compensating controls and an expiration date. Acceptance of a residual risk is a separate decision recorded in the Risk Register and follows the authority set in the risk charter: the Chief Operating Officer may accept Low residual operational risks involving public data, and no delegate may accept a risk involving PHI disclosure or waive a legal obligation. Every acceptance carries a review date and an expiry, and does not close the underlying remediation item.

16. Policy Review

This policy is reviewed at least annually, or upon material change to the Company's risk environment, regulatory obligations, or technology infrastructure, and is version-controlled as shown below.

Version History

Version	Date	Author	Summary of Changes
1.0	2025-06-01	Chris Morrissey, GRC Analyst	Initial policy issuance

1.1	2025-11-15	Chris Morrissey, GRC Analyst	Added Third-Party Risk Management section following vendor SOC 2 gap findings
1.2	2026-02-01	Chris Morrissey, GRC Analyst	Updated encryption-at-rest requirements; aligned control references to NIST CSF 2.0
1.3	2026-03-20	Chris Morrissey, GRC Analyst	Separated exceptions from enforcement and added risk acceptance authority, after ACC-014 showed the policy named only the CISO